

BEFORE Placeholder

AFTER

Integration Pattern: VPN / Private Link Connectivity (Supplier ↔ Organisation)

Document classification: Internal

Pattern owner: Security Engineering/Architecture

Version: 0.1

Approved for use with tiers: Critical (default), Important (exceptional), Low (not recommended)

Last review: _____

1. Purpose

This pattern defines when VPN/private link connectivity to a supplier is permitted and the minimum security controls required to reduce exposure (segmentation, least privilege routing, monitoring, and change control).

2. Default position

- Prefer **SaaS over the public internet with SSO + API** to avoid persistent network trust.
- VPN/private link is permitted only when required by the service design and justified by business need.
- **Inbound connectivity to organisational environments is avoided**; if required, it must be explicitly approved and tightly constrained.

3. When to use

Use this pattern when:

- the supplier provides an outsourced service requiring network-level connectivity, or
- legacy protocols or non-HTTP integrations require private routing, or

- regulatory/latency/availability constraints require private connectivity.

4. Preconditions (must be true before implementation)

MUST:

- Supplier tier confirmed (normally Critical).
- Data flows and systems in scope documented.
- Integration owner (IT/Platform) assigned.
- Logging/export pattern agreed (admin/auth + connectivity telemetry).
- Contractual commitments include incident notification and sub-processor transparency proportionate to tier.

5. Minimum security requirements (baseline)

5.1 Connectivity design

MUST:

- Use **least-privilege routing**:
 - only required subnets/hosts/ports
 - deny-all baseline with explicit allow rules
- Implement **segmentation**:
 - terminate connectivity in a controlled network zone (e.g., DMZ/integration segment)
 - prohibit flat routing into internal networks
- Use **separate connections** for:
 - production vs non-production (preferred)
 - different services where risk warrants

SHOULD:

- Use dedicated network devices/contexts for supplier connectivity where feasible.

- Prefer private connectivity options with explicit route controls over broad site-to-site VPNs.

5.2 Inbound connectivity (strongly restricted)

MUST:

- Avoid inbound connectivity by default.
- If inbound connectivity is required:
 - document the exact use case and technical necessity
 - restrict to specific source IPs/hosts and ports
 - require explicit approval per governance
 - implement enhanced monitoring and time-bound access where feasible

5.3 Authentication and encryption

MUST:

- Use strong cryptographic protocols for VPN tunnels (supplier and organisation standards).
- Use certificate/key management with defined rotation and ownership.
- Ensure tunnel credentials/keys are stored and handled securely.

SHOULD:

- Use certificate-based authentication where supported.
- Rotate keys/certificates on a defined schedule and on personnel changes.

5.4 Firewall and traffic controls

MUST:

- Enforce firewall rules on both ends (where possible) with:
 - explicit permitted ports/protocols
 - outbound restrictions (egress control)
 - no "any-any" rules
- Restrict DNS resolution and name access as appropriate to avoid broad discovery.

- Where file transfer is required, use controlled transfer patterns (avoid ad hoc SMB exposure).

SHOULD:

- Apply IDS/IPS or equivalent inspection for high-risk paths where feasible.
- Apply data loss controls (where feasible) for sensitive data flows.

5.5 Monitoring, logging, and alerting

MUST:

- Log:
 - tunnel up/down events and configuration changes
 - allowed/denied firewall flows (at least summary/metadata)
 - administrative actions affecting the connection
- Define monitoring ownership and response expectations.

SHOULD:

- Alert on:
 - tunnel flapping/instability
 - new/expanded routes
 - new ports opened
 - unusual traffic volumes or destinations
- Retain logs per retention policy (Critical recommended ≥ 12 months or internal standard).

5.6 Change control

MUST:

- Route additions, port changes, and rule changes require:
 - documented change request
 - security review/approval
 - implementation evidence and validation

- Reassessment required if connectivity scope increases materially.

5.7 Resilience and failover

MUST (Critical services):

- Define whether connectivity is single path or redundant.
- Document expected behaviour on failover and maintenance windows.

SHOULD:

- Use dual tunnels/links for Critical services where availability requirements demand it.
- Test failover at least annually (or per internal resilience standard).

6. Implementation steps (high level)

1. Confirm business need and justify VPN/private link vs SaaS/API alternatives.
2. Document data flows, endpoints, ports, and environments.
3. Design termination zone and segmentation boundaries.
4. Build deny-by-default firewall policy; add explicit allow rules only.
5. Configure tunnel with secure auth and key management; define rotation.
6. Enable logging and alerting; validate telemetry export.
7. Perform connectivity validation tests (functional + security).
8. Record evidence and sign off before production use.

7. Validation checklist (sign-off)

Record evidence location for each item.

Design: ☐ Justification documented (why private connectivity required)

☐ Data flows/endpoints/ports documented

☐ Termination zone and segmentation confirmed

Controls: ☐ Deny-by-default rules in place; explicit allow rules only
☐ No flat routing to internal networks
☐ Inbound connectivity not used, or explicitly approved and constrained

Crypto/keys: ☐ Secure tunnel configuration and authentication in place
☐ Key/certificate rotation owner and schedule defined

Monitoring: ☐ Tunnel events logged (up/down/config)
☐ Firewall flows logged (allow/deny as applicable)
☐ Alerts configured for route/port expansions and anomalies

Resilience: ☐ Availability model documented; failover expectations defined
☐ Test plan defined (Critical services)

Sign-off: Security Engineering/Architecture (role title): _____ Date: _____ IT/Platform
Owner (role title): _____ Date: _____ Business Service Owner (role title):
_____ Date: _____

8. Exceptions

Any of the following require an exception (and likely escalation) for Critical suppliers:

- broad routing beyond defined endpoints/ports
- inbound connectivity without strong constraints
- inability to provide adequate logging/auditability
- inability to enforce MFA for administrative access to connectivity components

9. Offboarding notes

On termination:

- decommission tunnels/links
- remove routes and firewall rules
- revoke/rotate any credentials/keys
- confirm monitoring alerts and runbooks are updated

- retain logs per retention policy